INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 2 Theory-Based Assignment:

GRC Regulatory Environment and Standards

Student Name: Najma Abdi Omar

Reg. No: **2025/GRC/10331**

Date: 30/07/2025

Credit: The answers provided here have been in consultation with week 2 study materials, all credits to the main material * unless otherwise stated.

Part A:

Q1. Answer:

Definition: Each organization has to adhere to certain laws, guidelines and specification relevant to their area of business. In the context of cybersecurity and information management, this entails having policies in place that meet requirements set by legal frameworks, industry standards or contractual agreements safeguarding data and ensuring maintenance of secure and private systems.

Benefits of Regulatory Compliance:

Below are some key benefits and examples:

1. **Legal Obligation:** Adhering to regulations ensures an organization is protected from legal repercussions associated with non-compliance, in form of fines or penalties or even criminal charges where applicable, an example is if measures are not put in place to comply with HIPAA(USA) one could face penalties based on severity of disclosure: knowingly obtaining or disclosing PHI could lead to up to 1 year in prison.

2. **Reputation Management:** Failure to comply may lead to damage in the organization's reputation in the society, a brand that fails to comply shows lack of integrity and may lose public trust, compliance goes

beyond penalty, it proves that an organization is worth partnering with, e.g. if a non-compliant organization may lose investors because no one wants to work with a company that doesn't maintain integrity, stakeholders and customers will not feel safe in dealing with such an organization.

3. **Risk Mitigation:** companies often benefit because the regulations were formulated to address risk around areas of work. E.g. compliance with PCI DSS reduces the risk associated with fraud in the payment card industry by reducing the possibility of accessing card details or card holder information.

4. **Competitive Advantage**: in a digital world where trust matters, compliance proves that an organization cares about the well-being of their client, as a client for examples choosing a third party vendor when assessing third party risk, I will choose a company that ISO 27001 certified over one that is vague on compliance.

5. **Ethical Responsibility:** Regulatory compliance assist an organization in ensuring there is trust and fair dealings, a compliant organization will be morally compliant too, e.g. part of compliance is to report a data breach no matter how small, this is ethical behavior driven by compliance.

Overall the greater benefit achieved by true compliance outweighs the discomfort in budgetary requirements and stakeholder alignment.

Q2: Evolution of the regulatory

Answer:

The past few decades have seen transformation in how businesses operate, the main drivers shaping regulations stem from **technological advancements, globalization, High-profile Incidents** to **changing public expectations** and **industry maturation** where market industries are competing for the same audience who know their rights and organizations can advance by showing how mature their security is.

In technology we have seen the shift from as little as paper-based industries to green initiatives where the world has gone digital, to the use of AI and most recently remote work has changed how organizations are viewed.

We also have **globalization** organizations operating across different countries and even continents a company may have various branches in different areas and there is need for a standard policy that ensure the customer experience is constant and security is not compromised.

High Profile Incidents major industries have been a target like the payment industry, after facing so many incidents and all having various policy, the industry formed a body that constituted the PCI DSS.

Q3. Compliance Challenges:

Answer:

There are challenges tied to achieving and maintaining Regulatory Compliance:

a. **Regulatory Complexity**: Regulations are complex in nature often inclusive of legal language that may be hard to interpret or implement, the volume of the output is huge and mapping of each compliance to the requirements is an intensive exercise. In highly regulated industries like health care and finance, this regulation may sometimes overlap and conflict making it hard to implement.

b. **Jurisdictional Variations:** the laws applicable to different areas or states vary and global industry have a conflict to which regulations to follow for uniformity or struggle to map their policies to fit each requirement in the operational jurisdiction.

c. **Rapid Regulatory Change**: Due to the increase in the nature of threats and change in threat landscape, regulations frequently change in an effort to keep up, it becomes a challenge for some organization to be in continuous change mode.

d. **Resource Constraints**: Regulatory compliance often requires extra resources whether it is the tools, the people or the general budget attached to compliance, this contributes to the view of compliance or security as a cost center which becomes a burden to proof ROI especially where the return is not immediate or visible to the average management.

e. **Technical Challenges:** adherence to regulations also comes with technological complexities like for example new technology or compatibility issues of legacy systems vs advance technology, sometimes a skill gap between the tools and the human resource who mans such tools etc.

f. **Cultural Resistance**: influencing the people to adhere to regulations, we can have the most complex of tools but convincing the user on the correct use or procedure is the most difficult part, case in point if an organization is used to doing changes without proper change management in place convincing them to comply to change management policy is hard, some might resort to check-box compliance and for example work backwards from implementation.

Part B: GDPR

Question 4

The GDPR is an EU regulation that seeks to protect the data rights and privacy of citizens of the EU regardless of where the data is processed or stored.

a) **EU-based organizations**: In EU Based organizations, the GDPR applies regardless of where the data is stored, for example an organization based in France with it data stored or processed in Kenya will be subjected to GDPR

b) **Non-EU organizations**: Any organization that targets or interacts with Individuals in EU whether it serves to offer goods or services or monitor the individual's behavior, as long as interacts with an EU individual is subject to comply with GDPR.

c)practical Scenarios:

Scenario one: a seller based in Kenya, selling products like local clothes, coffee etc to an individual in the EU, because I am processing data that includes details of an EU individual I should comply with GDPR.

Scenario two: Multinational organization seeking market entry to EU doing a market research on social media data and users in EU, has to comply regardless of where they are based, where the data is collected from and stored.

Question 5

Compare and contrast:

Answer:

The **data controller** dictates the policies and the way the data should be handled while the **processor** acts on the behalf of the controller only applying requirements and grounds set up by the controller.

Obligation	Data Controller	Data Processor
Legal Obligations and Adherence to GDPR	Ensure and demonstrate compliance with GDPR	Act as instructed by the controller and Make available to the controller all information to demonstrate compliance.
Reporting Data Breaches	Notify the supervisory authority with 72 hours where possible or without delay	Support the data controller, only act as per the controller guide.
Facilitate data Subject Rights	Implement mechanisms to address data subject requests effectively	Help Controller fulfill its obligation regarding data subject rights.
Data protection by design and by default	Implement data protection principles from designing systems to use the highest privacy settings by default.	Implement appropriate technical and organizational security measures in support of controller requirements.
Ensure Processor Compliance And confidentiality	Only use processors that provide sufficient guarantees to implement appropriate technical and organizational measures.	Ensure that persons authorized to process personal data have committed to confidentiality.
Maintain Records of Processing Activities	Document processing activities, including purposes, categories of data and data subjects, recipients, transfers, retention periods, and security measures.	The processor acts on behalf of the controller, under the controller's choice, delete or return all personal data after the end of the provision of services.

Question 6 GDPR PRINCIPLES:

We have seven fundamental principles for processing personal data established by GDPR,

1. **Purpose Limitation: Definition**: when collecting data, the company must be explicit in what they use the data for, and stick to what they said they will use it for. For example, in the bank the purpose of the personal data stated as KYC completion, the bank cannot reuse this KYC information for targeted commercials. **Challenges:** tempting to reuse data already there for purposes that benefit the organization like cross-selling **Solution:** Clearly documented use purpose of collected data, use of data classifications and limit usage to what was intentioned, ask for fresh consent if the data is to be repurposed, store the data away to prevent unnecessary access.

2. **Accuracy**: **Definition:** The data collected must be accurate and up to date. The **challenge**: it is hard to be updated with current data of individuals, because either the user may have moved, got a new title (Dr.), changed marital status and name etc. and without them contacting the organization it might be hard to know. **Solution:** employ digital solutions clearly defined mobile or internet banking platforms integrated to internal customer database, users are given options to auto-update details with clear guidelines, use of customer service representatives to reach out to clients and provide education or guidance in case of changes.

3. **Storage Limitation**: **Definition:** This principle guides on not keeping data longer than necessary and have systems in place to either anonymize or delete data no longer in use. **Challenges**: Fear of deleting data that might be “needed” later, legacy systems that do not support auto deletion and depend on human memory etc. **Solution:** policies that dictate data retention, systems that support auto deletion where possible, deleting data that is no longer in use after retention period, regular review of back up and archives by authorized personnel to catch data missed.

Part C: Healthcare and Financial Regulations

Question 7

Evaluate HIPAA framework.

HIPAA is a U.S. federal law that protects sensitive patient information, dictates how patient data is collected, used, stored and shared.

Discuss:

a) The scope and applicability of HIPAA

Anyone who has potential to interact with patient data, there are three categories in this scope: **The first category** are the ones who interact first hand with the patient and patient's data i.e. the healthcare providers this are the doctors, clinics, hospitals etc. that transmit data electronically, **Health Plans** inclusive of the organizations that work towards payment of patient's treatment and have sensitive information on the patient, and the other covered entities are the **clearing houses** i.e. the middle services that are entrusted with transfer of this information, usually behind the scenes not interacting with the patient but have access to the data. This group are referred to as the Covered Entities.

Business Associates: organizations that perform certain services for or on behalf of the covered entities this include freelance medical interpreters, the bridge between the doctor and the patient and must adhere to HIPAA.

Subcontractors: This are people or organization that are hired by the covered entities or Business associates to undertake certain tasks e.g. shredding, cloud storage etc. this group are also not directly interacting with the patient but by virtue of their association have access to data and hence must adhere to HIPAA.

All the three categories in the scope are bound by HIPAA even if someone doesn't work in the hospital or health care industry, as long as they interact with the patient's data one way, they have to abide by HIPAA all the way down the chain.

b) The key components:

Privacy Rule: individual rights to data, limits who has access to data, can amend, gives the patient the right to choose who to disclose their information with. This rule dictates all the ways in which data can be used, shared or accessed and the core controller and dictator remains the owner.

Security Rule: guarantees the right to protection from security incidents, it requires the groups in scope to implement various safeguards (Physical, administrative and technical) to ensure the data is safe and it mostly in relation to ePHI. It says" keep my data safe on computer systems"

Breach Notification Rule: dictates "tell me if my data leaks or is stolen" solidifies the right for an individual to be informed of a breach. dictates the number of days of notification i.e. 60 days after discovery. Who to notify and how i.e. the owner, the secretary HHS, media, business associates and the manner or nature of notifications i.e. the description of breach, type of information involved and how to a patient can protect themselves.

c) How HIPAA protects patient information and ensures healthcare data security:

HIPAA controls who can see patient information, protects access and notifies the patient if ever there is a breach. HIPAA Limits who can see or share medical information and ensures data is used in managing your care or treat you only, it ensures only you have the right to disclose any medical information seek permission if otherwise. HIPAA ensures digital and paper records are safe by enforcing policies and security awareness.

Question 8 PCI DSS

a) Who must comply with PCI DSS and why

Anyone handling card payments must comply with the PCI DSS. This includes: **Merchants**: entities that accept payment cards as a form of payment, they access sensitive card information if accessed by the wrong person can enable fraud. **Service providers,** entities that help in processing or keeping cards secure, entities that store, process or transmit cardholder data on behalf of another entity, e.g. a company that hosts an e-commerce website, could impact security of card holder data. **Financial institutions** involved in issuing payment cards or perform acquiring services, the core of payment card ecosystem and have direct impact on cards and security of cards and cardholder's data. The goal of PCI DSS is to protect card holder at every stage The reason for compliance is so that they can protect the card holder data, prevent or minimize fraud and also avoid penalties associated to non-compliance as set by the board.

b) The 12 requirements of PCI DSS (provide a brief description of each)

1. **Install and maintain network security controls**: an up to date firewall, updating network to ensure no security compromise leading to data breach or loss.

2. **Apply secure configurations to all systems and components**: a baseline and a good policy on change management and a good cyber hygiene like changing default passwords.

3. **Protect Stored Account Data:** ensuring the card data is safe and locked, only keep what is absolute necessary, ensure card data is not on full display at all times.

4. **Protect cardholder data with strong cryptography during transmission over open, public networks:** encryption of data in transit and use secure configs.

5. **Protect all systems and networks from malicious software:** antivirus that are up to date and have audit trails, and protect the system against malware

6. **Develop and maintain secure systems and software**: policies clearly documented dictating development or introduction of new software and also manage vulnerabilities by undertaking regular check and patches.

7. **Restrict access to system components and cardholder data by business need to know**: Limiting who can see or access the card data, defines access to those who need it and limit the rest using policies and procedures and system controls.

8. **Identify users and authenticate access to system components:** defines type of users and access to the card data, dictates that all users have unique credentials and no use of generic accounts to access card data info for proper identification and audit trail.

9. **Restrict physical access to cardholder data**: dictates locking up rooms and devices that have card data. It specifies how the controls should be in place for physical security.

10. **Log and monitor all access to system components and cardholder data**: track who does what, enforcing audit trail for all functions and people interacting with systems that have card data.

11. **Test security of systems and networks regularly**: Always check for vulnerabilities and fix them advocates for regular pentesting and system integrity checks.

12. **Support information security with organizational policies and programs**: Have clear rules, policies and guidelines that dictate data safety. Employ security awareness campaigns.

c) The different compliance levels and validation processes

Merchants and service providers are categorized based on transactions volumes and other factors.

Level1: merchants who have **over 6 million** transactions in a month or those who experienced a breach are held to higher standards of adherence to mitigate large scale risk.

Requirements: Annual report on compliance by a qualified security assessor, internal security assessor and quarterly network scans by an approved scanning vendor and attestation of compliance.

Level 2: Merchants processing **between one to 6 million** card transactions annually: Required to do an annual self-assessment and quarterly network scans and attestation of compliance.

Level 3: 20K to 1M e-commerce card transactions. Required: Annual SAQ and quarterly network scan

Level 4: fewer than 20k ecommerce card transaction or all other merchants under 1M card Transactions annually. Requirements: Annual SAQs, quarterly network scans by an ASV and AOC.

d) The consequences of non-compliance: The consequences of non-compliance are dire and include either Fines, Increased transaction fees or termination of the license or ability to process payment cards.

Part D: International Standards and Frameworks (20 points)

Question 9 (10 points)

Compare and contrast the following ISO standards:

The ISO standards have same underlying principles ensuring quality, safety and efficiency. Several frameworks are relevant for information security, privacy and risk management however they overlap at some point or complement each other,

- ISO/IEC 27001: Information Security Management: provides a structured guide in how we protect sensitive data and assists an organization implement a full information security management system. This can be used by any organization that is seeking to manage information security risk.

- ISO/IEC 27002: Security Controls: supports the ISO 27001, gives detailed guidelines on specific security controls, flexibility and best practice, useful to IT/security professionals implementing ISO 27001

- ISO/IEC 27701: Privacy Information Management: designed to assist an organization comply with data protection regulations, align with GDPR and other Privacy regulation requirements. Useful in organization handling PII.

- ISO 31000: Risk Management: unlike the ISO27001 which focuses specifically on information security, it looks at the organization wide risk. i.e. provides principle and guidelines for effective risk management, it focuses on any and all types of risks organization-wide.

Explain how these standards complement each other and how organizations can benefit from implementing multiple ISO standards.

This frameworks build and enhance each other's capabilities and guidelines, the ISO 27001 focuses on how to manage information security, complimented by the ISO 27002 security controls which gives best practices and how to implement the ISO 27001, gives flexibility on framework adoption, while ISO 27701 builds on privacy and how to handle PII giving more defined details and layered security on information security, and finally the organizational risk management ISO 31000

brings wider risk management approach, which now extends beyond the information and data security and extends to a bigger audience of enterprise wide risk management. An organization can benefit from implementing multiple ISO standards ensuring security on all layers, helping an organization protect data, manage risk and stay compliant.

Question 10 (10 points)

Cross-regulatory compliance.

Cross-regulatory compliance is a situation where an organization must comply with multiple regulations simultaneously it may pose challenges but if approached correctly may create room for integration efficiency. Example is a health care facility accepting card payments. This facility will have to adhere to HIPAA (Patient's data) and PCI DSS (card data).

Challenges:

We might find cases where we have conflicting requirements e.g., a certain framework might require data sharing and another might restrict, duplicated efforts in repeat tasks like audit, implementation and training. Cost implication and complexity of frameworks especially when implemented in Silos, variations in regulations depending on region and if not well coordinated departments may not work together which may lead to gaps and overlaps and wasted efforts.

Strategies:

Harmonizing compliance efforts across multiple regulations can improve **efficiency** and **effectiveness**. This can be **achieved by** developing a **unified compliance framework** and mapping the requirements to the framework, adopting **risk based approached** where the organization focuses on addressing high-risk areas first, allocate resources based on risk and make decisions that align on mitigating high risk high priority tasks. **Technology enablement** by adopting systems that will automate majority of repetitive tasks like audit and reports. Stakeholder engagement to ensure the **organization aligns** in the approach towards compliance by establishing clear roles and mapping how the teams complement and coordinate from implementation to reporting.